



Relatório de Auditoria de Segurança — JRC WhatsApp Broker

Fase 1

Incremento 1 — Backend multicliente e Baileys

Commit e8657c0

Data de referência 2026-09-03

DOCUMENTO DE CONTROLE E EVIDÊNCIA

Resumo executivo

Foram consolidados 1 achado(s), 12 ponto(s) forte(s) e 13 rotas públicas. O gate bloqueia exclusivamente achados CRITICAL ou HIGH em estado OPEN.

1

Achados

0

Bloqueantes

12

Pontos fortes

Escopo e nota metodológica

Escopo: backend multicliente, PostgreSQL/RLS, autenticação, RBAC, API keys, auditoria, instâncias, providers, OpenAPI, dependências, histórico Git JRC, bundles compilados e container. Frontend funcional, Meta real, filas e webhooks completos estão fora deste incremento.

Método: evidência em código e linhas, testes automatizados, inventário derivado do OpenAPI e scanners com saída sanitizada. O submódulo Evolution não é varrido historicamente; seu pin e sua fronteira são validados separadamente.

Categorias: CRITICAL — comprometimento imediato (P1); HIGH — impacto grave (P2); MEDIUM — impacto relevante condicionado (P3); LOW — hardening ou impacto limitado (P4); STRENGTH — controle positivo comprovado, sem efeito bloqueante.

CRITICAL

HIGH

MEDIUM

LOW

STRENGTH

Distribuição por severidade



Rosca por severidade

A rosca exclui INFO, reservado a contexto e não aplicabilidade. Ausência de segmentos indica zero achados CRITICAL, HIGH, MEDIUM ou LOW.

Evidências por categoria

AUTHENTICATION		1
AUTHORIZATION_RBAC		1
CONTAINER_RUNTIME		1
IDEMPOTENCY_DOS		1
IDOR		1
INPUTS_XSS		1
LOGGING_AUDIT		1
MULTITENANT_ISOLATION		1
OPENAPI_ROUTES		1
PROVIDER_BOUNDARY		1
RATE_LIMITING		1
SECRETS_CRYPTOGRAPHY		1
SUPPLY_CHAIN		1

Pontos fortes

JRC-STRENGTH-001

RLS forçada e contexto local à transação

As tabelas tenant usam FORCE ROW LEVEL SECURITY e o runtime aplica organization_id com set_config local.

JRC-STRENGTH-002

RBAC aplicado no backend

A matriz de papéis e permissões é avaliada pelo plugin Fastify antes dos handlers protegidos.

JRC-STRENGTH-003

API keys verificadas com HMAC e comparação constante

O segredo bruto é exibido somente na emissão; autenticação usa HMAC-SHA-256 e timingSafeEqual.

JRC-STRENGTH-004

Verificação Argon2id fictícia contra enumeração

Usuários ausentes executam verificação equivalente usando hash fictício inicializado no startup.

JRC-STRENGTH-005

Evolution isolada atrás do adapter

O cliente bloqueia redirects e propaga somente contratos e erros canônicos para os casos de uso.

JRC-STRENGTH-006

Ownership verificado antes de chamadas ao provider

Instâncias são buscadas no contexto da organização ativa e acesso cruzado retorna 404 sem invocar o adapter.

JRC-STRENGTH-007

Rate limit distribuído com chaves HMAC

O runtime usa Redis com TTL e deriva chaves opacas por HMAC para IP e identidade, aceitando encaminhamento somente de proxies confiáveis.

JRC-STRENGTH-008

Redaction estrutural conectada ao logger e auditoria

Campos e headers sensíveis são removidos por configuração do logger e metadados de auditoria são sanitizados antes da persistência.

JRC-STRENGTH-009

Idempotência tenant-aware com TTL

Operações mutáveis reservam chaves por organização e rota, detectam payload divergente e expiram registros sem serializar desafios.

JRC-STRENGTH-010

Dependências bloqueadas e auditadas no CI

O pipeline instala o lockfile com npm ci e bloqueia vulnerabilidades HIGH ou CRITICAL com npm audit.

JRC-STRENGTH-011

OpenAPI derivado da composição real e versionado

O documento é gerado pela aplicação Fastify, normalizado deterministicamente e comparado no CI com o contrato versionado.

JRC-STRENGTH-012

Imagem imutável e runtime não-root

A imagem fixa Node por versão e digest, separa build do runtime e executa o endpoint compilado como usuário node.

Pontos fracos

Nenhum ponto fraco aplicável.

Tabela de achados

ID	Categoria	Severidade	Estado	Arquivo/linhas
JRC-SEC-001	INPUTS_XSS	INFO	NOT_APPLICABLE	apps/web/README.md:3-3

Prioridades

Nenhuma prioridade aplicável.

Inventário de rotas

GET /v1/api-keys

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

Ownership: RLS_ORGANIZATION_FILTER

Handler: apps/api/src/http/routes/api-keys.ts:133

POST /v1/api-keys

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

Ownership: ACTIVE_ORGANIZATION_CONTEXT

Handler: apps/api/src/http/routes/api-keys.ts:115

DELETE /v1/api-keys/{id}

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID

Handler: apps/api/src/http/routes/api-keys.ts:150

POST /v1/auth/login

NONE · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: NOT_APPLICABLE_PRE_AUTH

Handler: apps/api/src/http/routes/auth.ts:148

POST /v1/auth/logout

REFRESH_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_FAMILY_BOUND

Handler: apps/api/src/http/routes/auth.ts:246

POST /v1/auth/refresh

REFRESH_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_TENANT_BOUND

Handler: apps/api/src/http/routes/auth.ts:223

POST /v1/auth/select-organization

SELECTION_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: SELECTION_TOKEN_MEMBERSHIP_REVALIDATED

Handler: apps/api/src/http/routes/auth.ts:192

GET /v1/instances

JWT_OR_JRC_API_KEY · instances:read · RLS SIM

Ownership: RLS_ORGANIZATION_FILTER_AND_TENANT_CURSOR

Handler: apps/api/src/http/routes/instances.ts:152

POST /v1/instances

JWT_OR_JRC_API_KEY · instances:connect · RLS SIM

Ownership: RLS_PROVIDER_ACCOUNT_AND_ORGANIZATION

Handler: apps/api/src/http/routes/instances.ts:126

GET /v1/instances/{id}

JWT_OR_JRC_API_KEY · instances:read · RLS SIM

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID

Handler: apps/api/src/http/routes/instances.ts:169

POST /v1/instances/{id}/connect

JWT_OR_JRC_API_KEY · instances:connect · RLS SIM

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/instances.ts:183

POST /v1/instances/{id}/disconnect

JWT_OR_JRC_API_KEY · instances:connect · RLS SIM

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/instances.ts:226

GET /v1/instances/{id}/status

JWT_OR_JRC_API_KEY · instances:read · RLS SIM

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/instances.ts:211

Issues completas

--- ISSUE 1 ---**JRC-SEC-001 — Verificações exclusivas de XSS no frontend não se aplicam ao Incremento 1****Contexto**

O Incremento 1 entrega somente backend e não contém superfície HTML/JavaScript funcional.

Evidência

`apps/web/README.md:3`: `O Incremento 1 não contém implementação funcional de frontend.`

Condições de exploração

A verificação passa a ser aplicável quando o painel web ou qualquer resposta HTML funcional entrar no produto.

Impacto

Nenhum impacto aplicável ao runtime atual; inputs da API continuam no escopo.

Correção

Criar especificação e testes próprios de XSS antes do Incremento 2.

Critérios de aceite

- Manter o diretório web sem implementação funcional neste incremento.
- Auditar o frontend antes de sua publicação.

Verificação

Inspecionar a composição HTTP e o conteúdo de `apps/web`.

Labels sugeridas

`security`, `not-applicable`, `frontend`

--- FIM ISSUE 1 ---